Схема взаимодействия [центробанк ГЦИ]

Предварительные шаги:

- создать банковский сертификат в Vault, под которым будут выдаваться клиентские сертификаты - intermediate CA
    - можно исопльзовать утилиту от ЦБ и импортировать в Vault либо средствами Vault
- настроить Kong на работу с mTLS для сервиса GCI Adapter, импортировать public key банковского сертификата (используется Kong для проверки подписи клиентских сертификатов).
- настроить в Rong АПИ для проксирования запроса в ГЦИ, настроить определение пути обращения и заполнения header
- (под вопросом) создать отдельную пару ключей private / public для подписи JWT-токена - access token, передать public key в ГЦИ для последующей проверки подписи JWT
    - как вариант - выставить jwks ендпоинт с public key

Подход к проксированию:

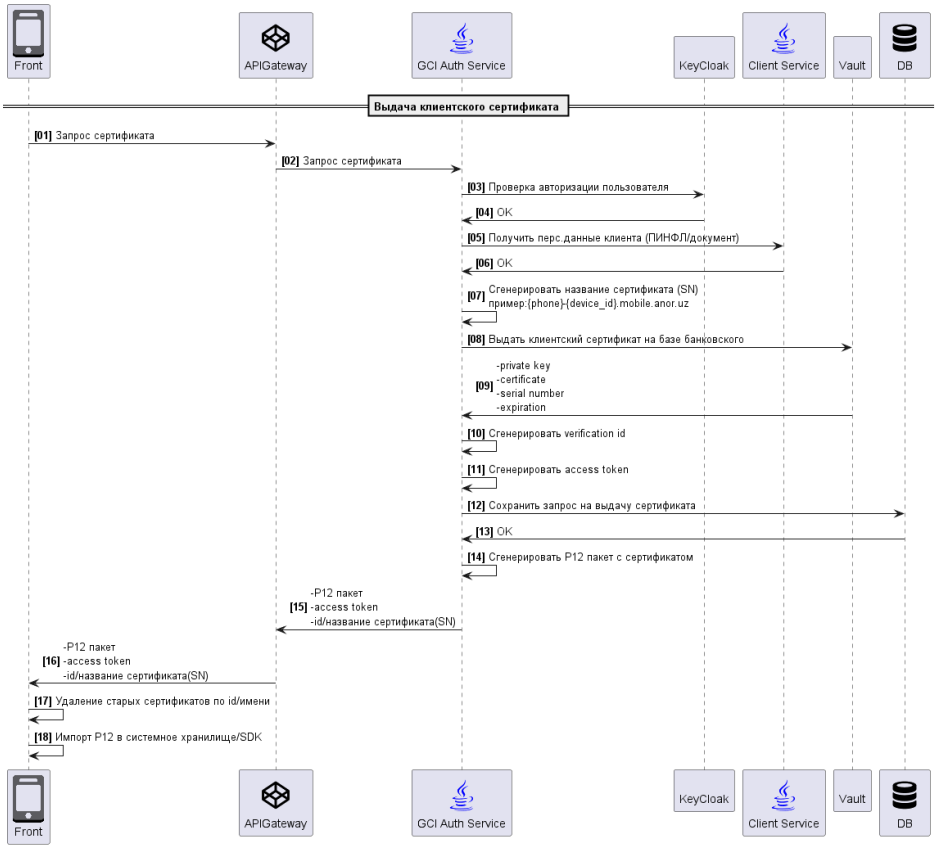
- проксируем вслепую, т.е. ничего не знаем о структуре запроса, ответа и внутреннем пути АПИ ГЦИ. Знаем только хост ГЦИ
- на фронте для SDK задаем базовый путь банка для запросов в виде http://anorbank.uz/api/v1/identity/verification этот же путь мы заводим в Kong как АПИ
- SDK шлет запрос на адрес: базовый путь + ендпоинт ГЦИ (например, /api/v1/gsi/verify). Получается адрес http://anorbank.uz/api/v1/identity/verification/api/v1/gsi/verify
- Kong для настроенного АПИ (http://anorbank.uz/api/v1/identity/verification) настраивается так, чтобы перенаправить запрос до сервиса бэка и остаток пути обернуть в header. Получается запрос (АПИ уже бэк сервиса gci) http://gci-adapter/api/v1/identity/verification, header X-Gci-Path: /api/v1/gsi/verify
- сервис проксирует запрос до хоста ЦБ, добавляя путь из X-Gci-Path: https://face.mbabm.uz/api/v1/gsi/verify

Запрос на выдачу сертификата (предварительно)

Plant UML

```
@startuml

!include <tupadr3/devicons/java>
!include <aws/General/mobileclient/mobileclient>
```

```
!include <tupadr3/devicons/database>
!include <tupadr3/devicons/codepen>
!include <tupadr3/devicons/redis>

participant "<$mobileclient>\nFront" as frontend
participant "<$codepen>\nAPIGateway" as gw
participant "<font color=blue><$java>\nGCI Auth Service" as auth
participant "<font color=blue>\nKeyCloak" as idp
participant "<font color=blue><$java>\nClient Service" as client
participant "<font color=blue>\nVault" as vault
participant "<$database>\nDB" as db

autonumber "<b>[00]"
== Выдача клиентского сертификата ==

  frontend -> gw: Запрос сертификата
  gw -> auth: Запрос сертификата

  auth -> idp: Проверка авторизации пользователя
  idp -> auth: OK

  auth -> client: Получить перс.данные клиента (ПИНФЛ/документ)
  client -> auth: OK

  auth-> auth: Сгенерировать название сертификата (SN)\nпример:{phone}-
{device_id}.mobile.anor.uz

  auth -> vault: Выдать клиентский сертификат на базе банковского
  vault -> auth: -private key\n-certificate\n-serial number\n-expiration

  auth -> auth: Сгенерировать verification id
  auth -> auth: Сгенерировать access token

  auth -> db: Сохранить запрос на выдачу сертификата
  db -> auth: OK

  auth -> auth: Сгенерировать P12 пакет с сертификатом

  auth -> gw: -P12 пакет\n-access token\n-id/название сертификата(SN)

  gw -> frontend: -P12 пакет\n-access token\n-id/название сертификата(SN)

  frontend -> frontend: Удаление старых сертификатов по id/имени
  frontend -> frontend: Импорт P12 в системное хранилище/SDK

@enduml
```

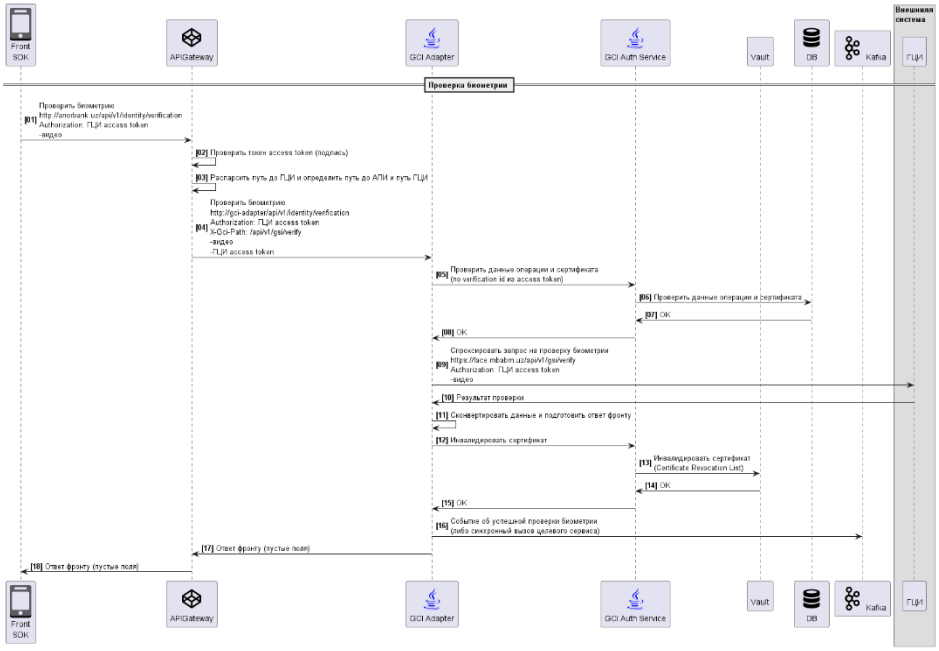


Запрос на проверку биометрии (предварительно)

Plant UML

```
@startuml

!include <tupadr3/devicons/java>
!include <aws/General/mobileclient/mobileclient>
!include <tupadr3/devicons/database>
!include <tupadr3/devicons/codepen>
!include <cloudinsight/kafka>

participant "<$mobileclient>\nFront\nSDK" as frontend
participant "<$codepen>\nAPIGateway" as gw
participant "<font color=blue><$java>\nGCI Adapter" as adapter
participant "<font color=blue><$java>\nGCI Auth Service" as auth
participant "<font color=blue>\nVault" as vault
participant "<$database>\nDB" as db
participant "<$kafka>Kafka" as kafka

box Внешнияя\nсистема
participant "<font color=blue>\nГЦИ" as gci
end box

autonumber "<b>[00]"
== Проверка биометрии ==
```

```
  frontend -> gw: Проверить
биометрию\nhttp://anorbank.uz/api/v1/identity/verification\nAuthorization:
ГЦИ access token\n-видео
  gw -> gw: Проверить токен access token (подпись)
  gw -> gw: Распарсить путь до ГЦИ и определить путь до АПИ и путь ГЦИ

  gw -> adapter: Проверить биометрию\nhttp://gci-
adapter/api/v1/identity/verification\nAuthorization: ГЦИ access token\nX-Gci-
Path: /api/v1/gsi/verify\n-видео\n-ГЦИ access token

  adapter -> auth: Проверить данные операции и сертификата\n(по verification
id из access token)
   auth -> db: Проверить данные операции и сертификата
   db -> auth: OK
  auth -> adapter: OK

  adapter -> gci: Спроксировать запрос на проверку
биометрии\nhttps://face.mbabm.uz/api/v1/gsi/verify\nAuthorization: ГЦИ access
token\n-видео
  gci -> adapter: Результат проверки

  adapter -> adapter: Сконвертировать данные и подготовить ответ фронту

  adapter -> auth: Инвалидировать сертификат
    auth -> vault: Инвалидировать сертификат\n(Certificate Revocation List)
    vault -> auth: OK
  auth -> adapter: OK

  adapter -> kafka: Событие об успешной проверки биометрии\n(либо синхронный
вызов целевого сервиса)

  adapter -> gw: Ответ фронту (пустые поля)

  gw -> frontend: Ответ фронту (пустые поля)

@enduml
```


Внешняя система
Front SDK
APIGateway
GCI Adapter
GCI Auth Service
Vault
DB
Kafka
ГЦИ
Проверка биометрии
[01] Проверить биометрию
http://mobank.uz/api/v1/identity/verification
Authorization: ГЦИ access token
-видео
[02] Проверить токен access token (подпись)
[03] Распарсить путь до ГЦИ и определить путь до АПИ и путь ГЦИ
[04] Проверить биометрию
http://gci-adapter/api/v1/identity/verification
Authorization: ГЦИ access token
X-Gci-Path: /api/v1/gsi/verify
-видео
-ГЦИ access token
[05] Проверить данные операции и сертификата
(no verification id из access token)
[06] Проверить данные операции и сертификата
[07] OK
[08] OK
[09] Спроксировать запрос на проверку биометрии
https://face.mbabm.uz/api/v1/gsi/verify
Authorization: ГЦИ access token
-видео
[10] Результат проверки
[11] Сконвертировать данные и подготовить ответ фронту
[12] Инвалидировать сертификат
[13] Инвалидировать сертификат
(Certificate Revocation List)
[14] OK
[15] OK
[16] Событие об успешной проверки биометрии
(либо синхронный вызов целевого сервиса)
[17] Ответ фронту (пустые поля)
[18] Ответ фронту (пустые поля)